Agent Operation Authentication (Dapeng)

AOA: Problem Statement & Design Goals

Current OAuth Limitations in AI Agent Context:

1. Permission ≠ Behavior (The Injection Risk)

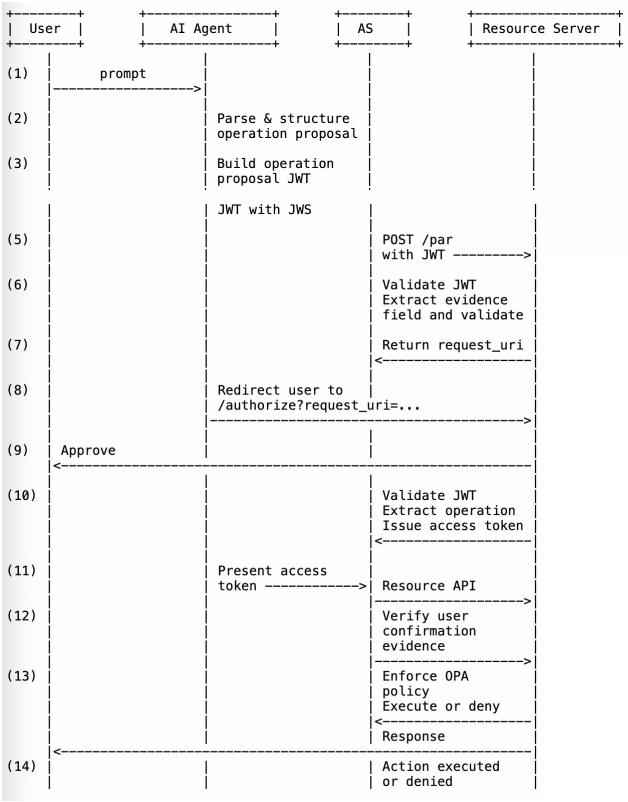
- **Current OAuth**: Grants broad Permissions (e.g., scope=write).
- **The Risk**: Since LLMs struggle to distinguish **Data vs. Instruction**, a **Prompt Injection** can trick the Agent into executing malicious actions that are still technically within the granted Permission.
- **Gap**: A mechanism to **bind specific behavioral policies** with OAuth authorization.

2. The Agent Delegation Challenge (Intent Decoupling)

- **Hallucination in Parsing intent:** The Agent may misinterpret the user's natural language intent.
- **Missing Contextual Binding:** Current OAuth proves who the user is, but not **which Agent is acting which user and what specific task** was authorized.
- **Gap: L**ack a cryptographic link for "Agent X acting for User Y to do Task Z".

Design Goals: Bind behavioral Policy +Agent Delegation + User Intent Evidence into the Access Token.

Workflow & Native Multi-Agent Support



(1) User says: “Add something cheap to cart on Nov 11 night”

(2) AI Agent parses intent → builds operation proposal object

(3) Agent creates operation proposal JWT

(4) Agent creates JWT with operation proposal claim, signs with JWS

(5) Agent sends JWT to AS via PAR: POST /par { "request": "<jwt>" }

(6) AS validates JWS, extracts evidence field and validate

(7) AS issues request_uri to agent

(8) Agent redirects user to /authorize?request_uri=...

(9) User reviews the displayed operation and confirms the authorization

(10) AS register the policy and issues Agent Operation Authorization Token as access token which includes the policy_id

(11) Agent uses token to access Resource Server

(12) AS verifies user confirmation evidence

(13) RS enforces OPA policy

(14) Action executed or denied